Exploiting Union-Based SQL Injection (SQLi) in Lab Environments

Introduction

According to OWASP, injection, which includes SQL Injection (SQLi), was the 5th most common vulnerability in 2025. Due to how common the vulnerability is, it is essential for website penetration testers to know how to do SQLi. It occurs when an application improperly filters user input, allowing an attacker to interfere with the queries that an application makes with a database.

These instructions are focused specifically on UNION-based SQLi, which leverages the UNION SQL operator to combine the results on the intended query with the results of the new malicious query. By the end of this tutorial, you should be able to exfiltrate hidden data from a MySQL database.

Legal Warning

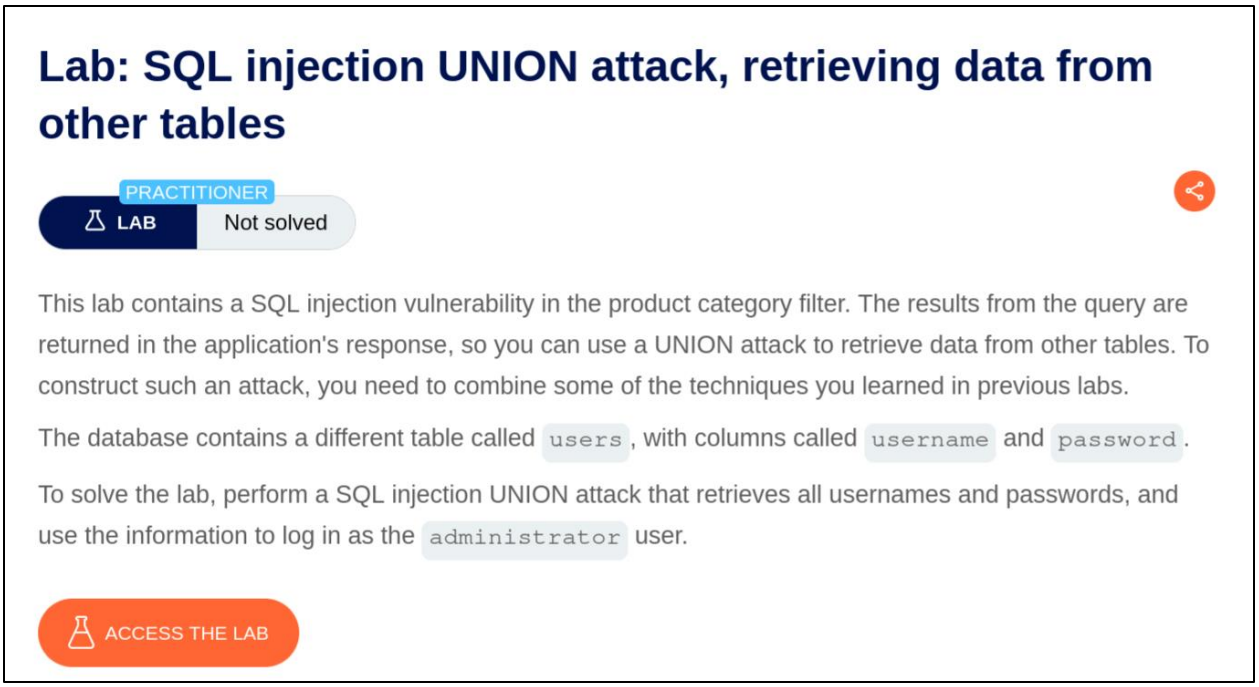
The techniques described in this document are for educational and authorized testing purposes only. Performing SQLi on an active environment is a violation of the CFAA (Computer Fraud and Abuse Act). Only perform SQLi on applications that you have permission for.

Glossary

- **Payload:** String of code sent to the server to run an exploit.
- **Commenting out:** Using SQL characters (like -- or #) to tell that database to ignore the rest of the application's original query.
- **URL Encoding:** Converting characters into a format that can be transmitted over the internet (e.g., a space becomes %20).
- **Endpoint:** where the API sends and receives responses.
- **NULL Value**: A marker used in SQL to indicate that a data value does not exist in the database.

Tools Required

- Firefox Web Browser with Developer Tools enabled
- An instance of Portswigger Academy's Lab "Lab: SQL injection UNION attack, retrieving data from other tables"

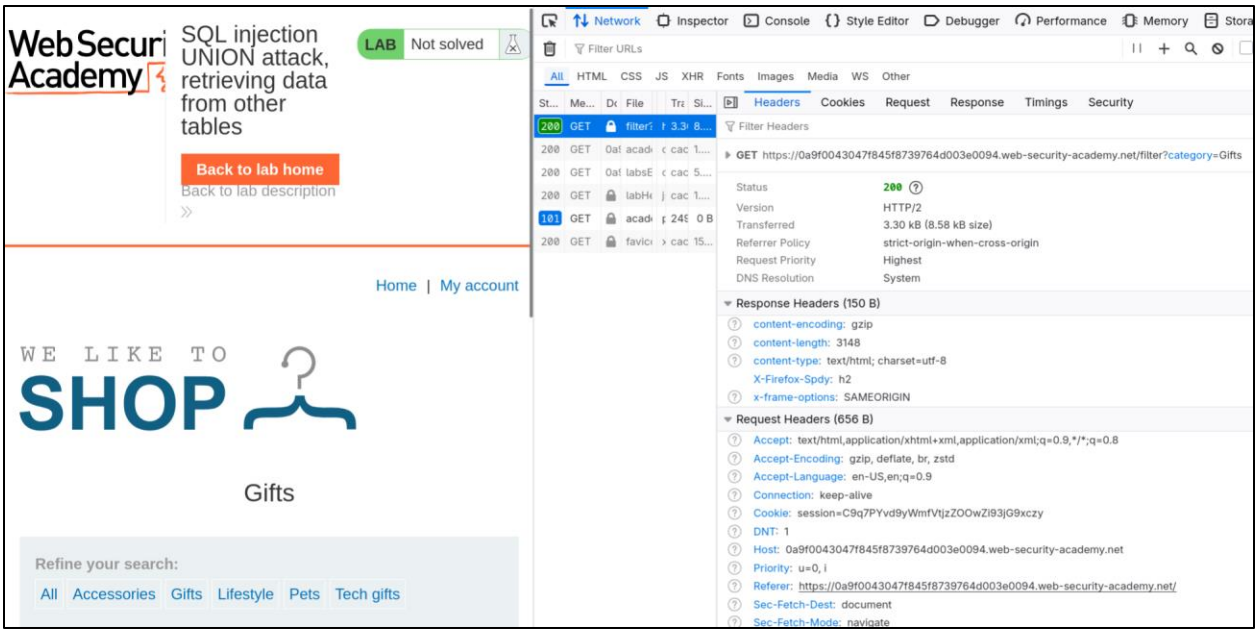


The Portswigger Academy lab page titled "SQL injection UNION attack, retrieving data from other tables," showing the lab description and Access the Lab button.

Phase 1: Reconnaissance

After loading the site, locate the vulnerability. Since the vulnerability is in the product category filter function, test that endpoint.

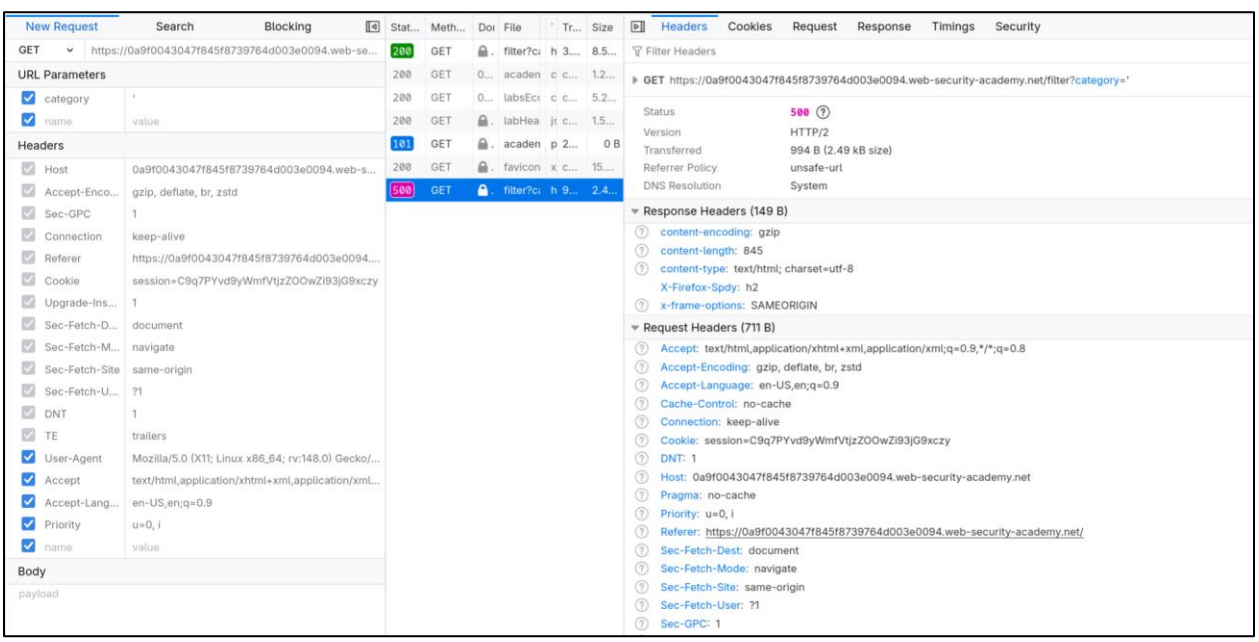
1. Click on the Gifts category.
2. Open the Developer Tools for your browser and then open the Network Tab.
3. Refresh the page to see the request.



Firefox Developer Tools Network tab showing a GET request to the filter endpoint with the Gifts category parameter and a 200 response.

To test if this endpoint is vulnerable, insert special characters like the apostrophe (‘) into the query. If the endpoint is vulnerable, the apostrophe will break the query syntax and return an error.

4. Right click on the request and choose “Edit and Resend”.
5. Enter only an apostrophe (‘) in the category URL parameter field.



Firefox Developer Tools showing a 500 Internal Server Error response after sending an

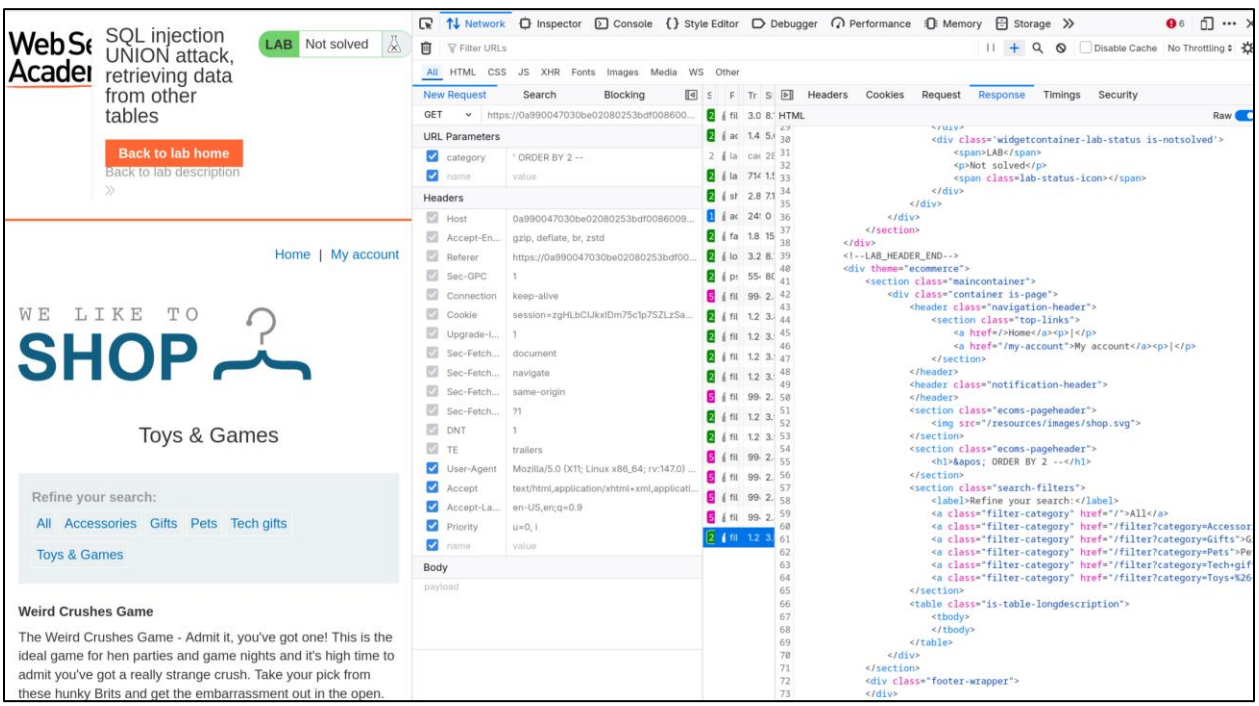
apostrophe as the category parameter value.

Phase 2: Query Structural Analysis

Now that the endpoint is confirmed vulnerable to SQLi, determine how many columns the original query has. In SQL, UNION works by combining two requests with the same number of columns.

However, since the original query's column count is unknown, use the ORDER BY function to determine it. The ORDER BY clause works by having the number after it being the column used in sorting when returning the results in a query. If ORDER BY encounters a column number greater than the query's column count, or less than 1, the server will return an error. Use this behavior to identify the exact column count.

6. In the same "Edit and Resend", use `' ORDER BY # --` in the category URL parameter field.
7. Send the request.
8. Stop when the server returns a 200 response. That number is the column count.

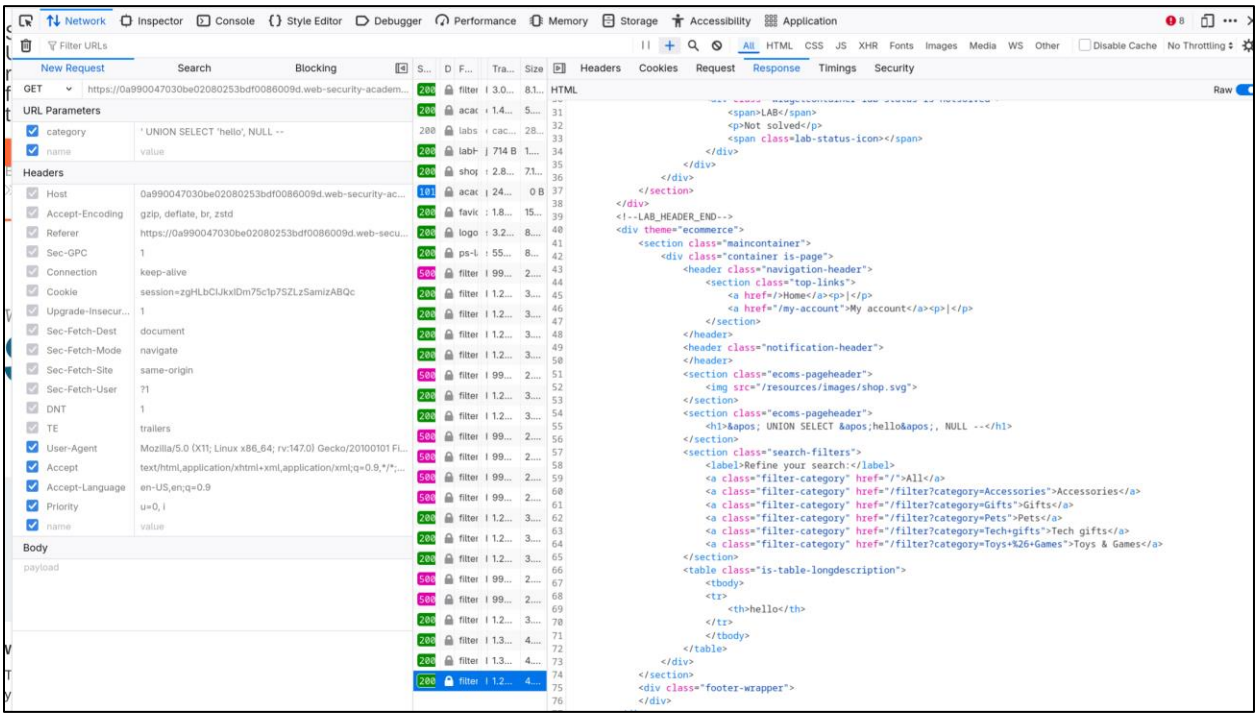


Firefox Developer Tools showing a 200 response after sending ' ORDER BY 2 --, confirming the query has two columns.

If `' ORDER BY 2 --` returns a 200 response, the query has two columns.

9. Send `' UNION SELECT 'hello', NULL --` in the category URL parameter field.

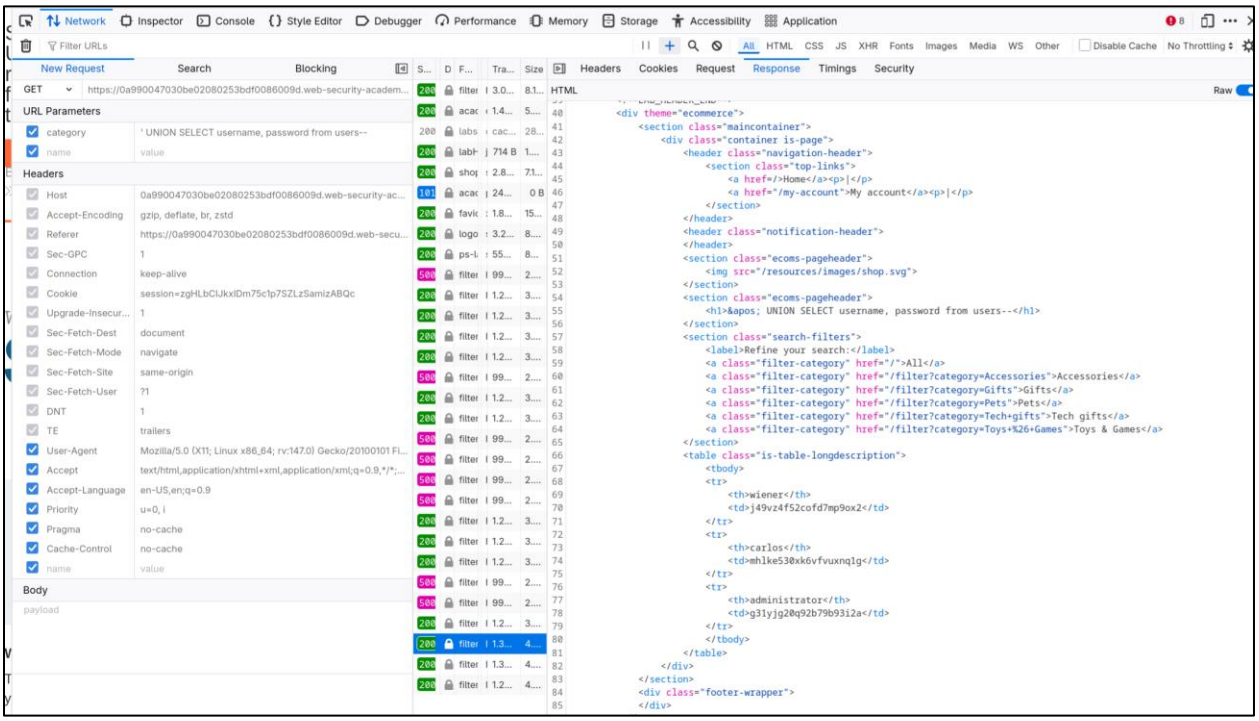
10. Then send ‘ UNION SELECT NULL, ‘hello’ -- and observe which payload returns "hello" on the page. That parameter supports string output.



Firefox Developer Tools Response tab showing "hello" rendered on the page after sending ‘ UNION SELECT ‘hello’, NULL --.

After trying both queries, both parameters support strings. Proceed to the final step.

Phase 3: Data Exfiltration



Firefox Developer Tools Response tab showing all usernames and passwords from the users table returned after sending the UNION SELECT payload.

11. Send ‘ UNION SELECT username, password FROM users -- in the category URL parameter field to retrieve all usernames and passwords from the database.

Troubleshooting

Do NOT use the apostrophe from this document since it has a different Unicode number than the apostrophe coming from your keyboard. If you are having problems with the payloads, make sure you are using the apostrophe from your keyboard.

Conclusion

Congratulations! You have successfully exploited an SQLi vulnerability in a Lab environment. By manually determining the number of columns and data types, you have gained an understanding of SQLi that automated tools cannot provide.